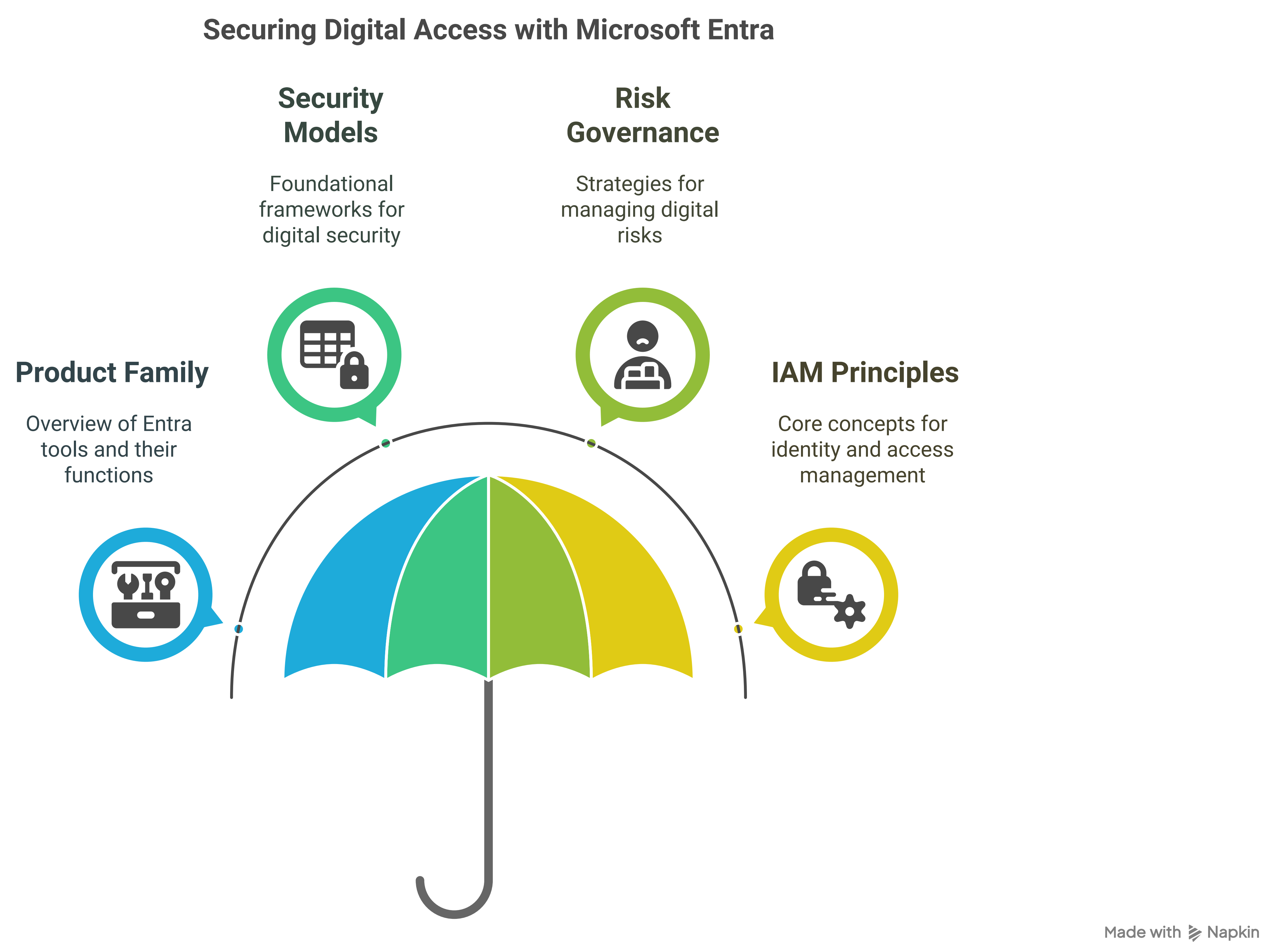
Securing Digital Access: Microsoft Entra & Identity Concepts

@mpurushotham

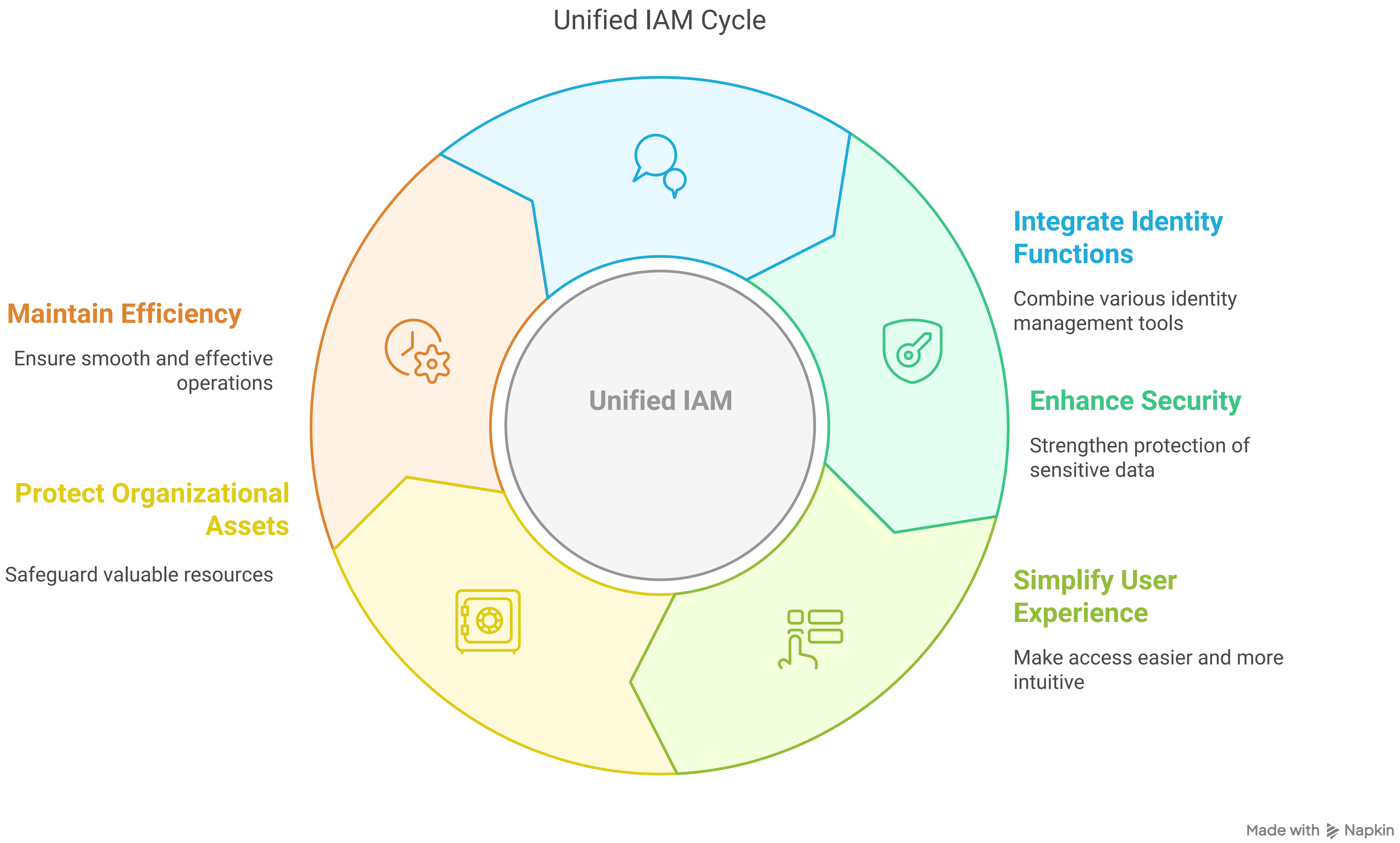
This document provides a comprehensive overview of Microsoft Entra's product family and the core security and identity concepts essential for securing digital access. It outlines the tools available within the Entra ecosystem, including their functionalities and practical applications, while also delving into foundational security models, risk governance, and key identity and access management (IAM) principles. The aim is to equip readers with a clear understanding of how to effectively manage identities and secure access in a digital landscape.


Securing Digital Access with Microsoft Entra
Security Models
Foundational frameworks for digital security
Risk Governance
Strategies for managing digital risks
Product Family
Overview of Entra tools and their functions
IAM Principles
Core concepts for identity and access management
Made with Napkin

🪟 I. MICROSOFT ENTRA PRODUCT FAMILY (The Tools) 🛠️‼️

Microsoft Entra (Overall Brand)

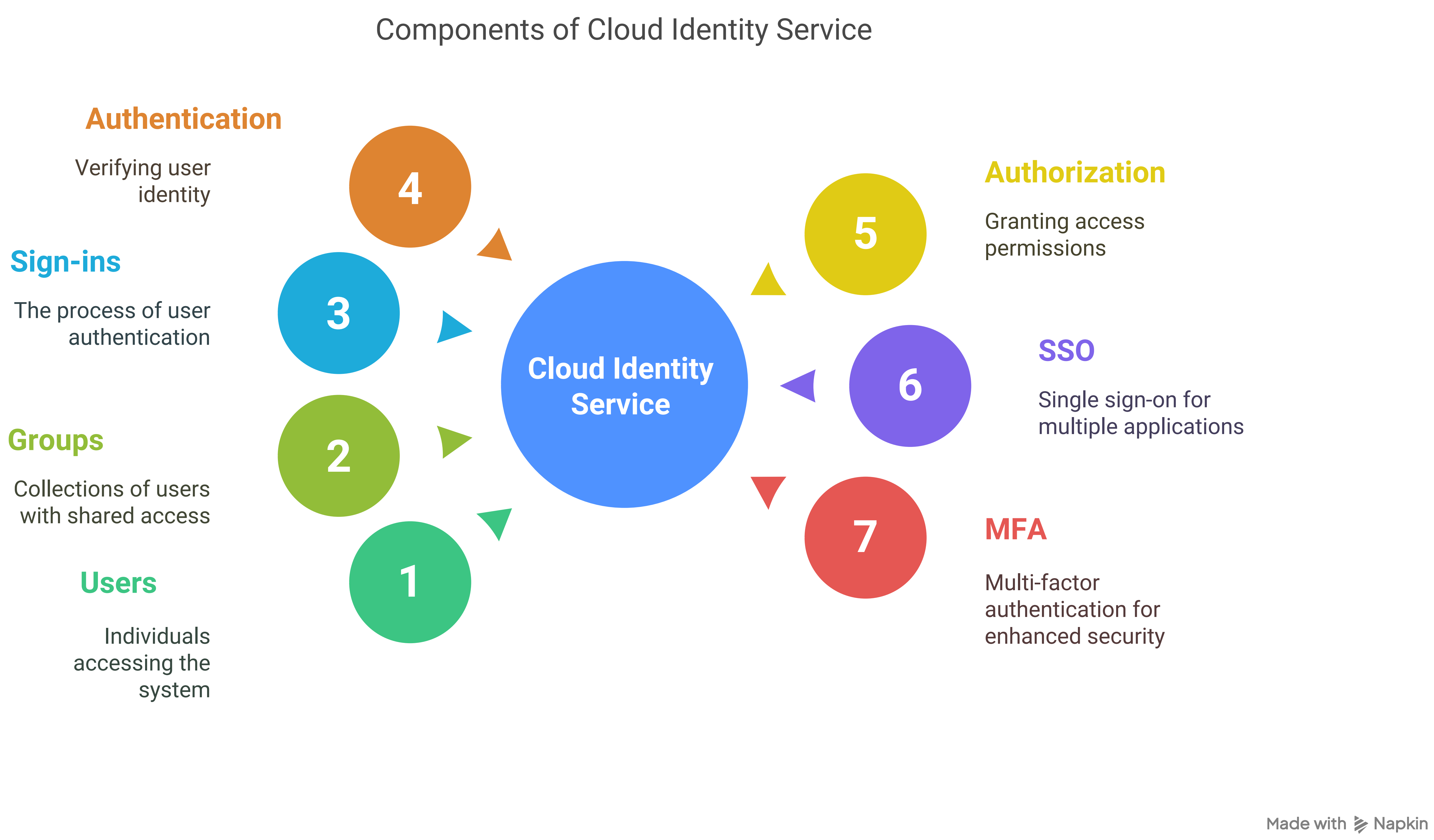
- **What:** Unified Identity & Access Management



Unified IAM Cycle
Integrate Identity Functions
Combine various identity management tools
Enhance Security
Strengthen protection of sensitive data
Simplify User Experience
Make access easier and more intuitive
Protect Organizational Assets
Safeguard valuable resources
Maintain Efficiency
Ensure smooth and effective operations
Unified IAM
Made with Napkin

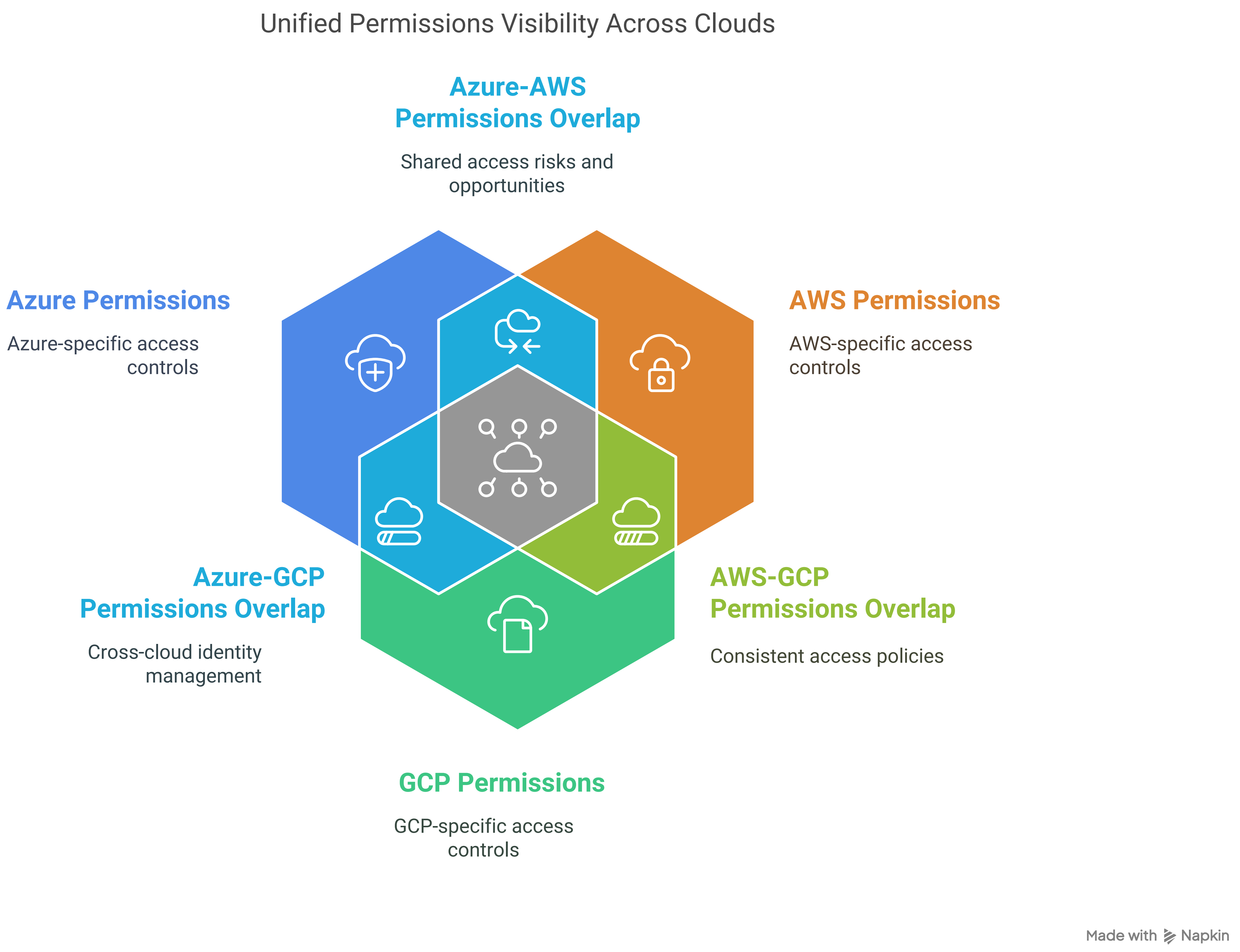
Entra ID (Core Foundation - Formerly Azure AD)

- **What:** Cloud Identity Service (Users, Groups, Sign-ins)
- **Why:** Authentication, Authorization, SSO, MFA Foundation
- **Example:** Employee Login to M365/Salesforce


Components of Cloud Identity Service
Authentication
Verifying user identity
4
Sign-ins
The process of user authentication
3
Groups
Collections of users with shared access
2
Users
Individuals accessing the system
1
Cloud Identity Service
Authorization
Granting access permissions
5
SSO
Single sign-on for multiple applications
6
MFA
Multi-factor authentication for enhanced security
7
Made with Napkin

Entra Permissions Management (CIEM)

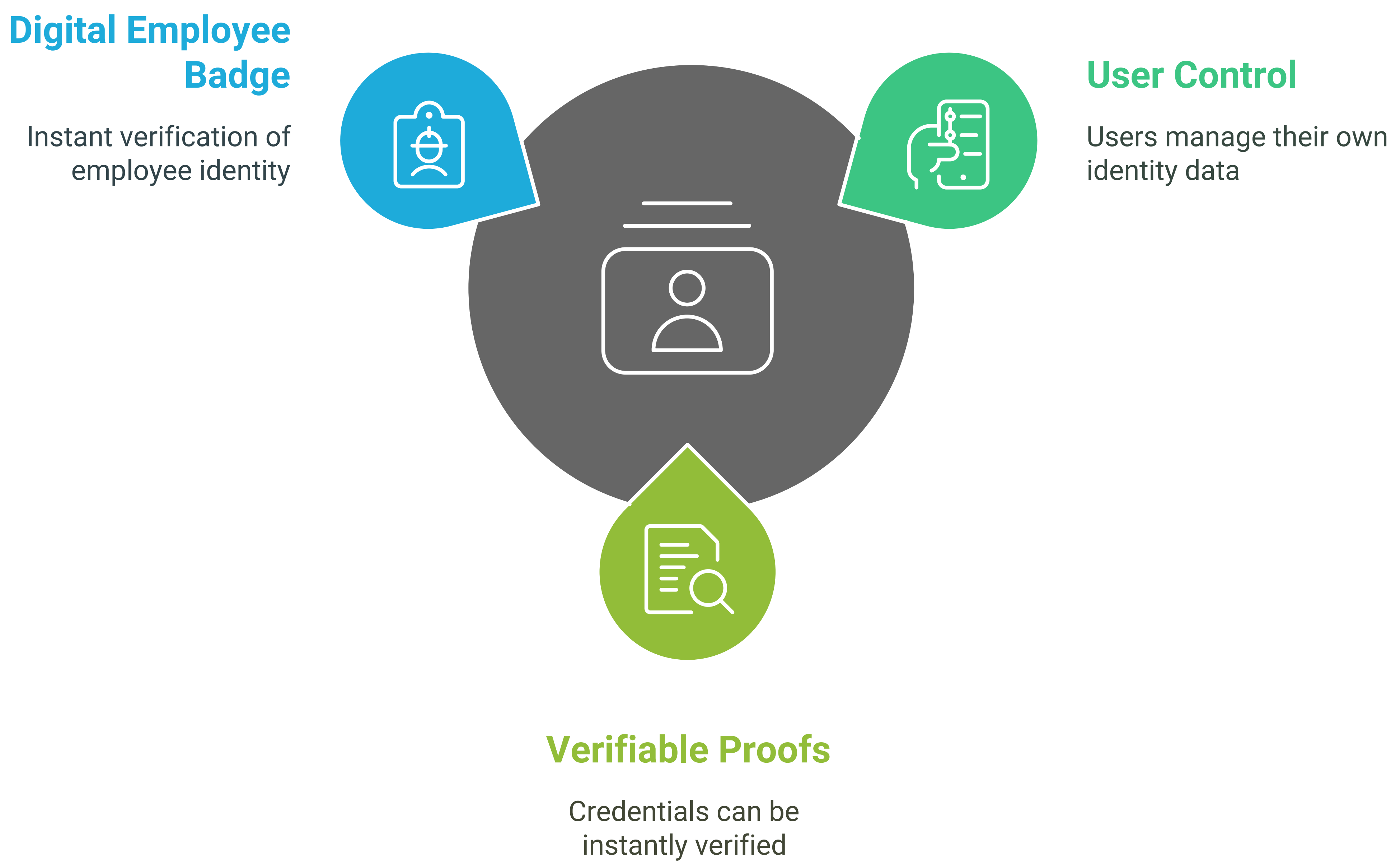
- **What:** Multi-Cloud Permissions Visibility (Azure, AWS, GCP)
- **Why:** Discover & Right-size Permissions, Least Privilege Across Clouds
- **Example:** Finding over-privileged AWS access from Azure


Unified Permissions Visibility Across Clouds
Azure-AWS
Permissions Overlap
Shared access risks and opportunities
Azure Permissions
Azure-specific access controls
AWS Permissions
AWS-specific access controls
Azure-GCP
Permissions Overlap
Cross-cloud identity management
AWS-GCP
Permissions Overlap
Consistent access policies
GCP Permissions
GCP-specific access controls
Made with Napkin

Entra Verified ID

- **What:** Decentralized Identity Credentials
- **Why:** User-Controlled, Verifiable Proofs (Skills, Employment)
- **Example:** Digital Employee Badge for Instant Verification

Decentralized Identity Credentials



Entra Identity Governance

- **What:** Identity Lifecycle & Access Assurance Tools
- **Why:** Ensure Right Access, Right Time (Reviews, Requests, PIM)
- **Example:** Automated Manager Access Reviews

Identity Lifecycle and Access Assurance Cycle

1

Review Access

Regularly assess user access rights

2

Request Changes

Initiate modifications to access permissions

3

Implement Changes

Apply approved access changes

4

Monitor Access

Track and verify access effectiveness

5

Automate Reviews

Schedule and conduct automated access reviews

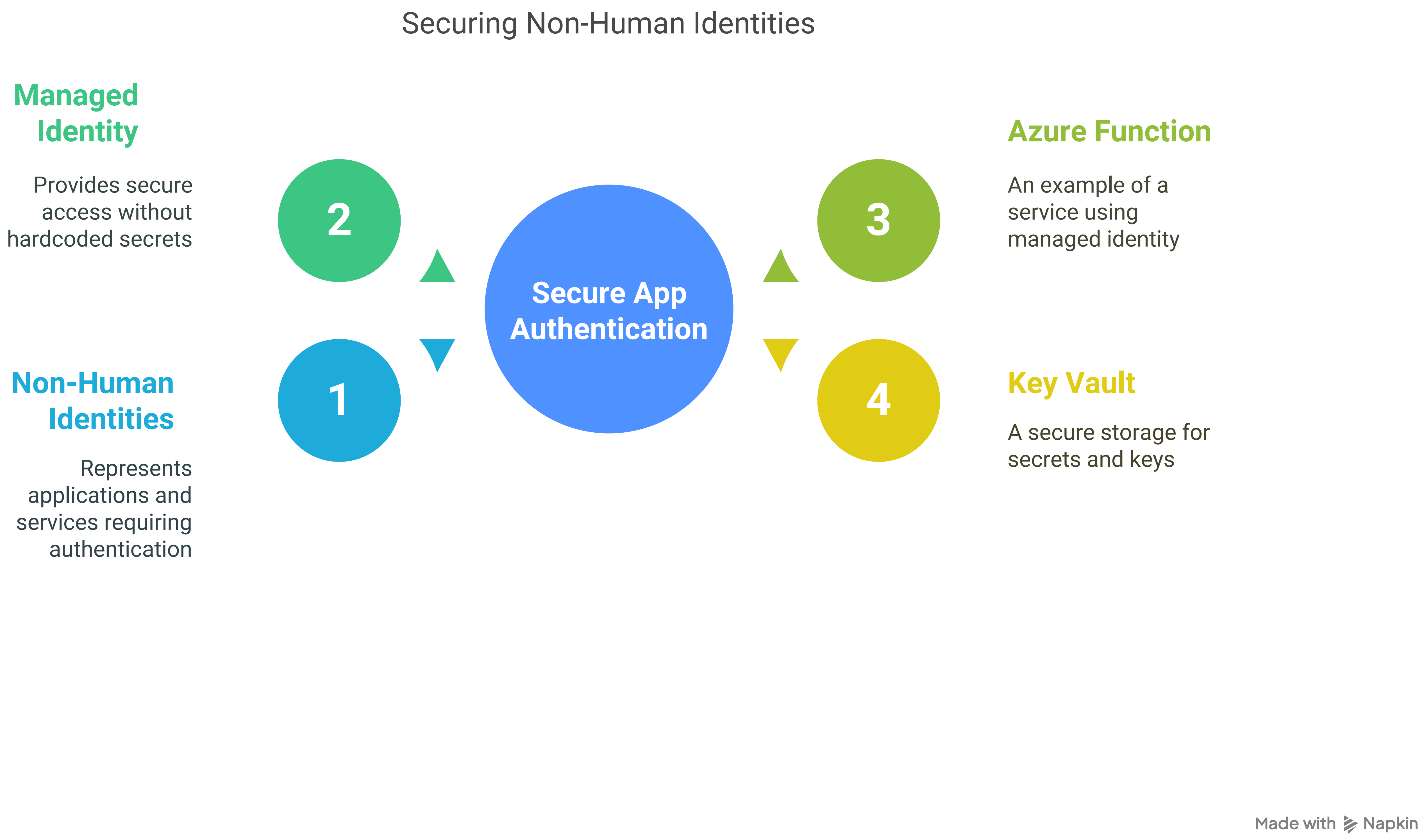
Entra External ID (B2B/B2C)

- **What:** Manage Customer, Partner, Guest Identities
- **Why:** Secure External Access to Your Apps
- **Example:** Customer login to your web store via Google

Securing External Access

Entra Workload ID

- **What:** Secure Non-Human Identities (Apps, Services)
- **Why:** Secure App Authentication (No Hardcoded Secrets)
- **Example:** Azure Function using Managed Identity for Key Vault

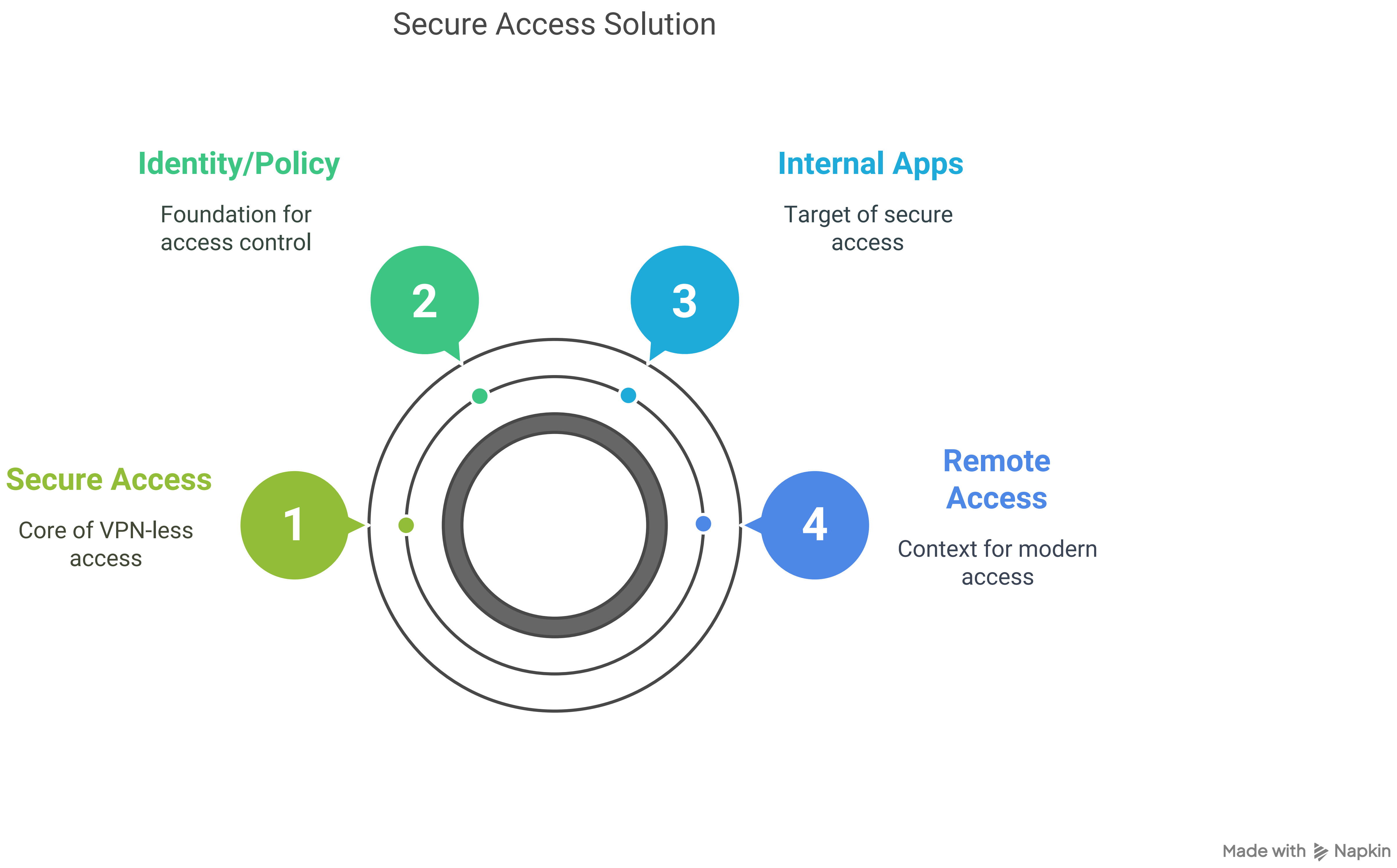


Securing Non-Human Identities
Managed Identity
Provides secure access without hardcoded secrets
2
Non-Human Identities
Represents applications and services requiring authentication
1
Secure App Authentication
3
Azure Function
An example of a service using managed identity
4
Key Vault
A secure storage for secrets and keys
Made with Napkin

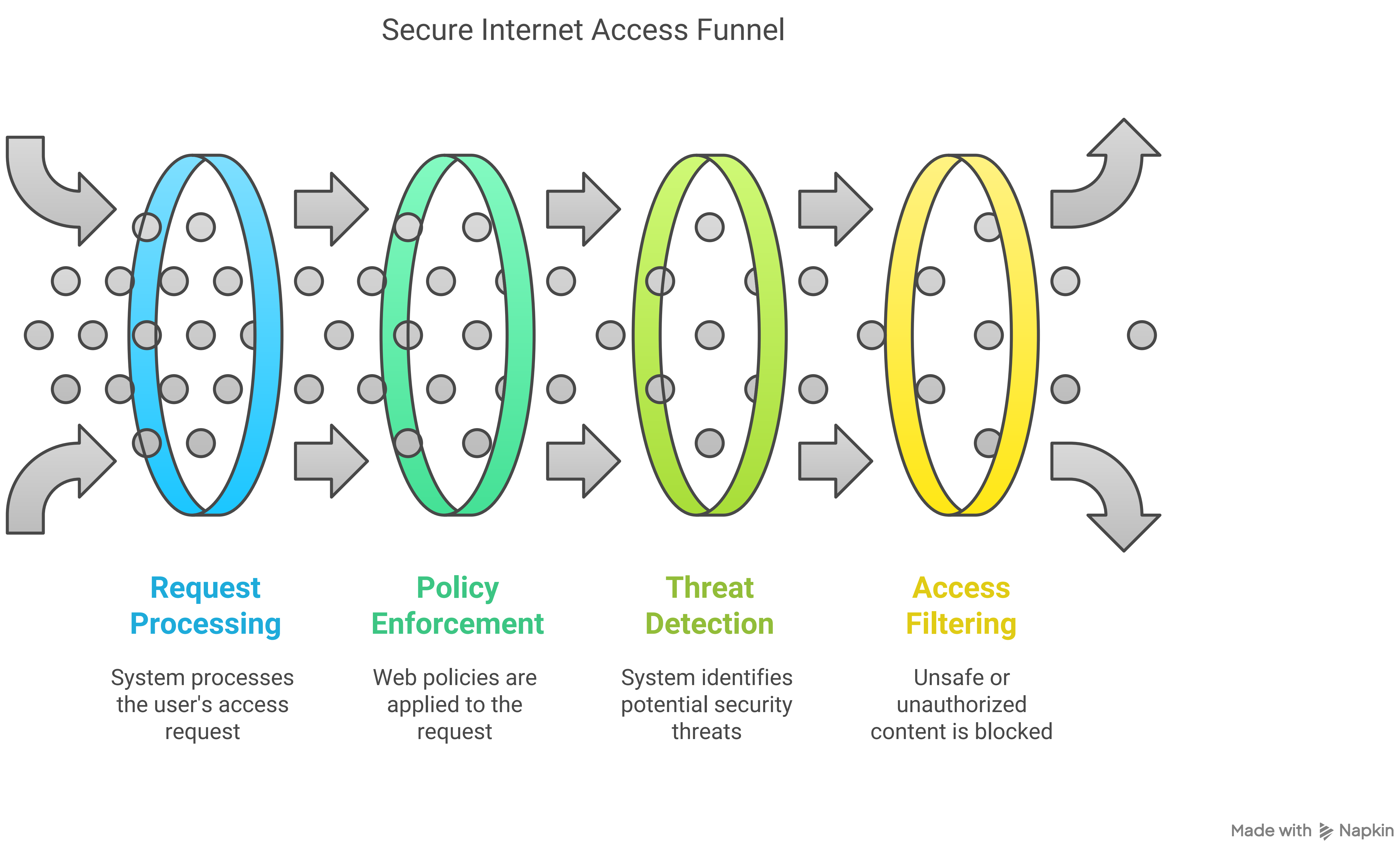
Global Secure Access (SSE Umbrella) 🌐

Entra Private Access (ZTNA)

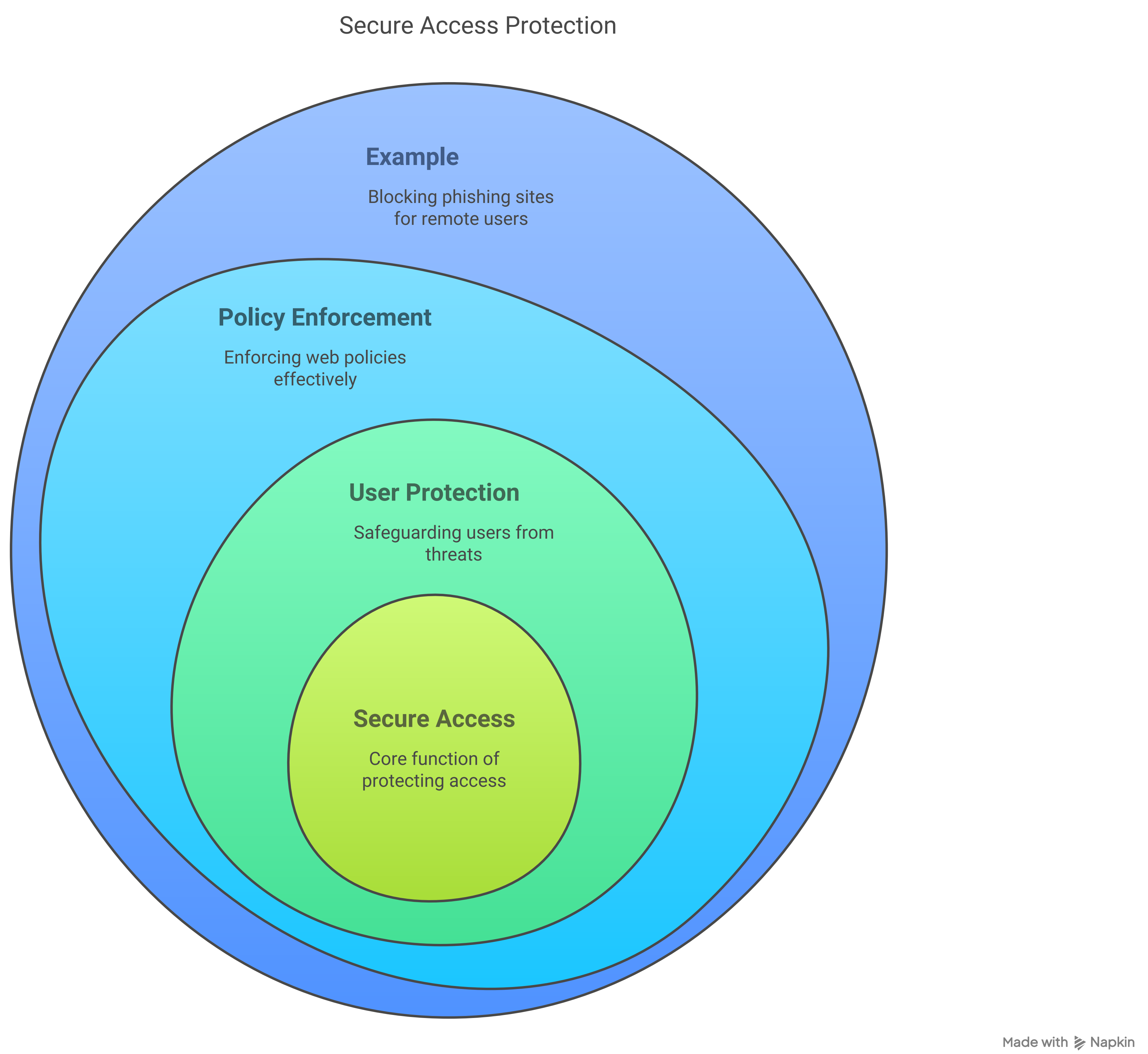
- **What:** Secure Access to Internal Apps (VPN-less)
- **Why:** Modern Remote Access based on Identity/Policy
- **Example:** Accessing On-Prem HR Portal via Browser Securely


Secure Access Solution
Identity/Policy
Foundation for access control
Internal Apps
Target of secure access
2
3
Secure Access
Core of VPN-less access
1
4
Remote Access
Context for modern access
Made with Napkin

Entra Internet Access (SWG/Filtering)


Secure Internet Access Funnel
Request Processing
System processes the user's access request
Policy Enforcement
Web policies are applied to the request
Threat Detection
System identifies potential security threats
Access Filtering
Unsafe or unauthorized content is blocked
Made with Napkin

- **What:** Secure Access to Internet/SaaS Apps
- **Why:** Protect Users, Enforce Web Policies Anywhere
- **Example:** Blocking Phishing Sites for Remote Users


Secure Access Protection
Example
Blocking phishing sites for remote users
Policy Enforcement
Enforcing web policies effectively
User Protection
Safeguarding users from threats
Secure Access
Core function of protecting access
Made with Napkin

II. CORE SECURITY & IDENTITY CONCEPTS (The Principles & Frameworks) 🏛️‼️

Foundational Security Models

- **CIA Triad:** Confidentiality, Integrity, Availability (Goals)
- **Defense in Depth:** Layered Security (Castle Analogy)
- **Zero Trust Model:** Never Trust, Always Verify (Modern Approach)
- **Cloud Shared Responsibility:** Provider Secures OF Cloud, You Secure IN Cloud

Foundations of Digital Security

CIA Triad

Ensures data confidentiality, integrity, and availability.

Defense in Depth

Employs multiple security layers for robust protection.

Zero Trust Model

Verifies every access request to prevent breaches.

Cloud Shared Responsibility

Divides security tasks between provider and user.

Risk & Governance

- **Security Threats:** The Dangers (Malware, Phishing, etc.)
- **GRC:** Governance, Risk, Compliance (Oversight & Rules)
- **IAM Governance:** Policies/Processes for Managing Identities

Cybersecurity and Governance Landscape

High Security Threats

Security Threats

Security Threats highlight vulnerabilities despite low governance oversight.

IAM Governance

IAM Governance ensures robust identity management policies amidst high threats.

Low Governance

High Governance

Basic Security Measures

Basic Security Measures offer minimal protection with low governance.

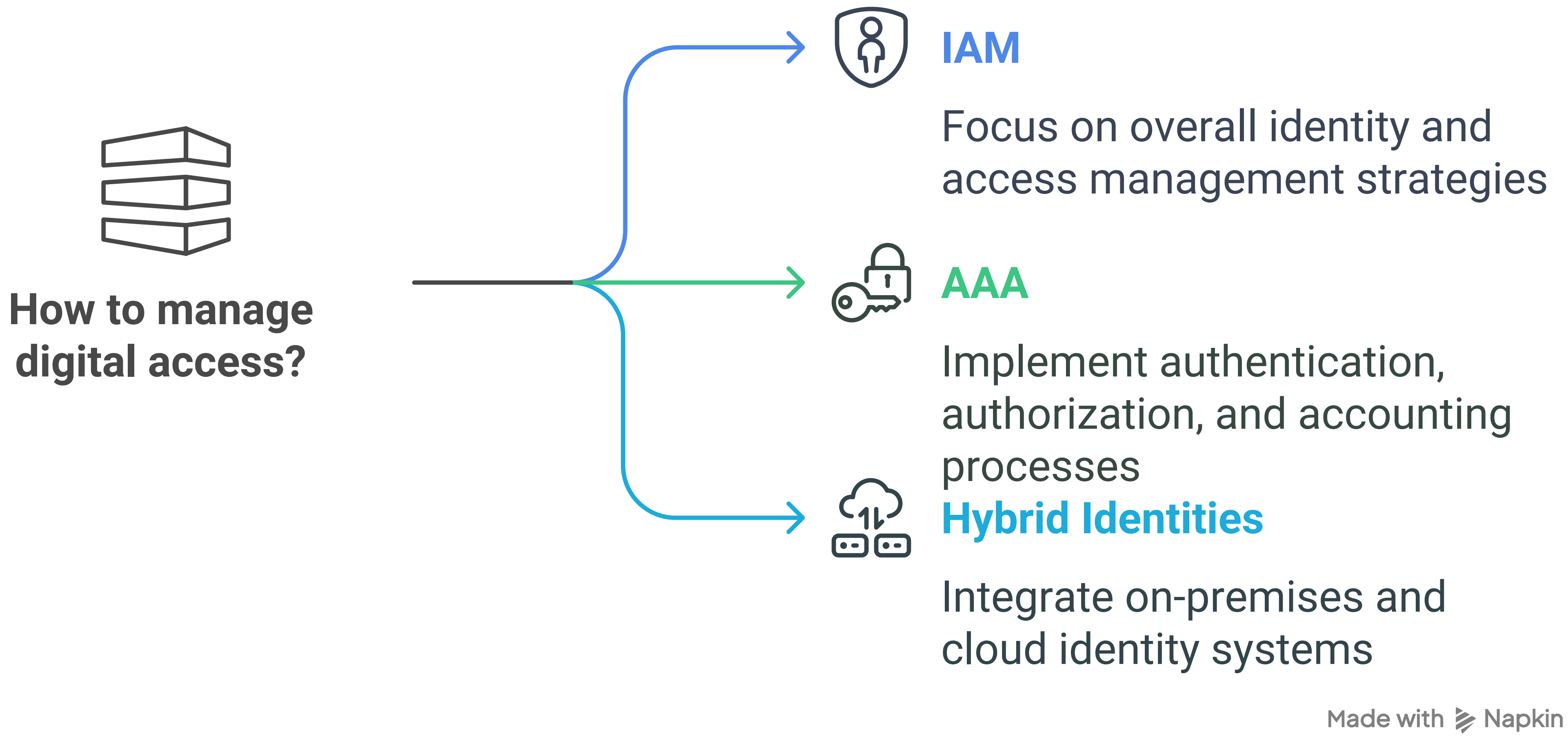
GRC Framework

GRC Framework provides structured oversight with minimal security threats.

Low Security Threats

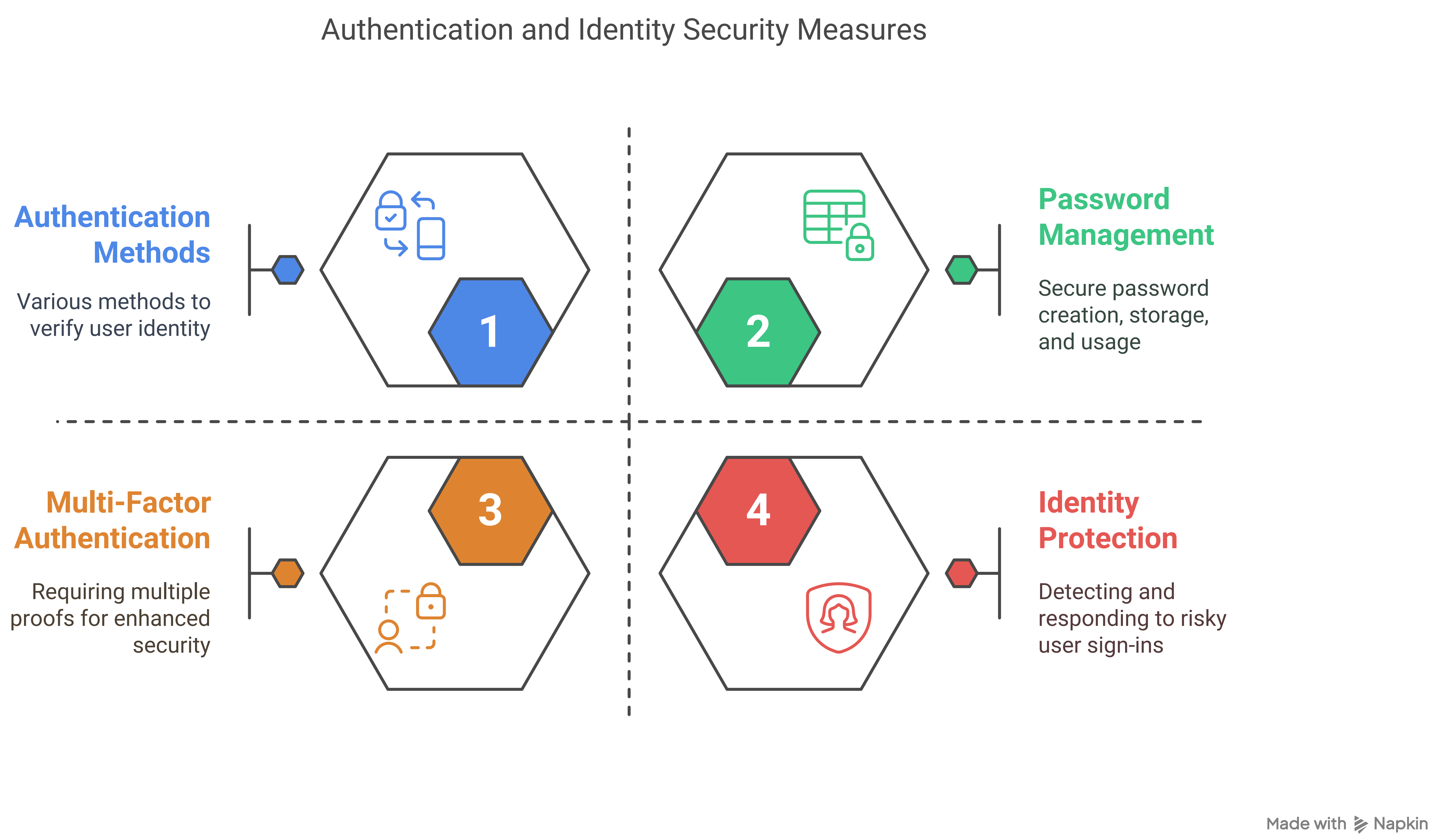
Core IAM Functions

- **IAM:** Identity & Access Management (The Discipline)
- **AAA:** Authentication (Who?), Authorization (What?), Accounting (Log)
- **Hybrid Identities:** On-Premises AD + Cloud (Entra ID) Sync



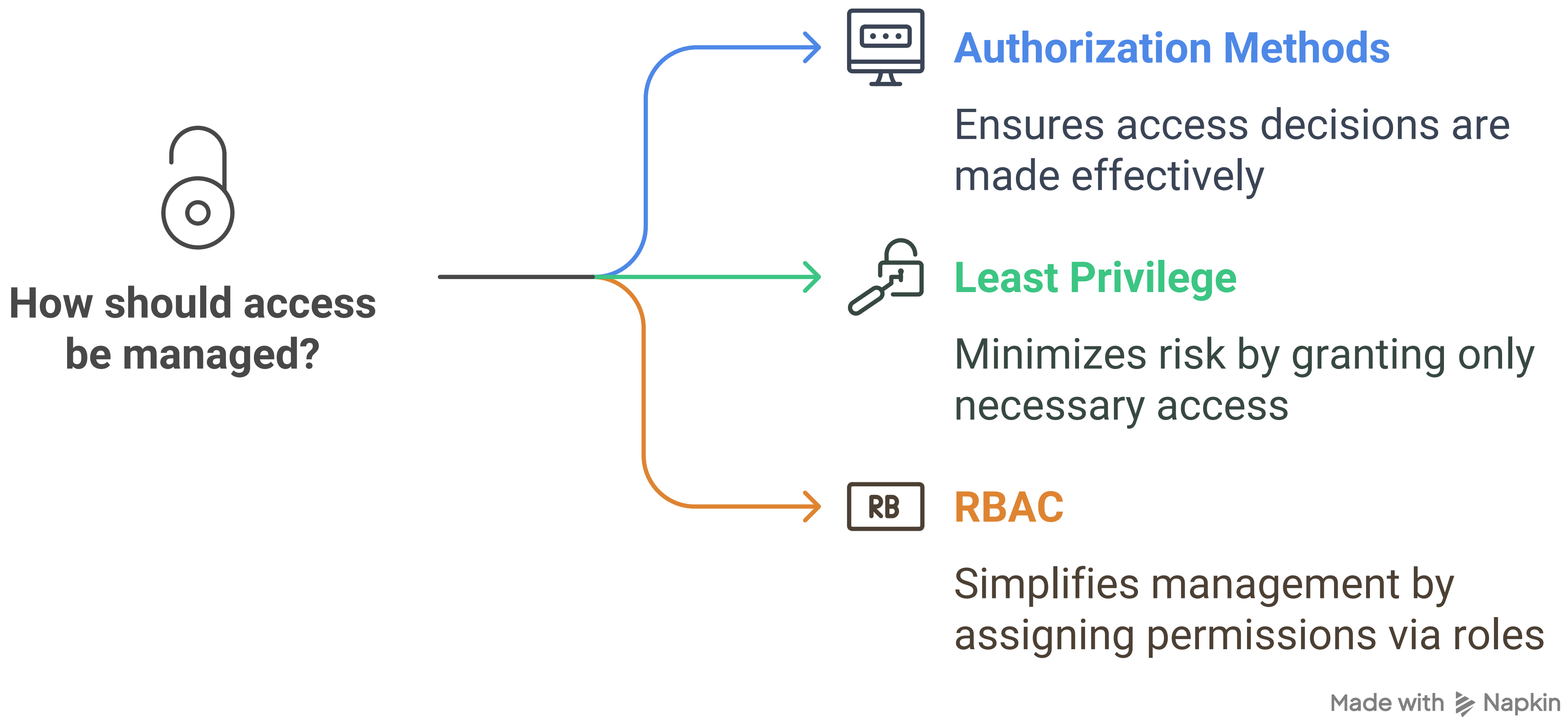
Authentication (Proving Who You Are)

- **Authentication Methods:** Passwords, Biometrics, Keys, Apps...
- **Password Management:** Secure Creation, Storage, Use
- **MFA (Multi-Factor Auth):** KEY CONTROL - Need Multiple Proofs
- **Identity Protection:** Detect & Respond to Risky Sign-ins/Users


Authentication and Identity Security Measures
Authentication Methods
Various methods to verify user identity
1
Password Management
Secure password creation, storage, and usage
2
Multi-Factor Authentication
Requiring multiple proofs for enhanced security
3
Identity Protection
Detecting and responding to risky user sign-ins
4
Made with Napkin

Authorization (What You Can Do)

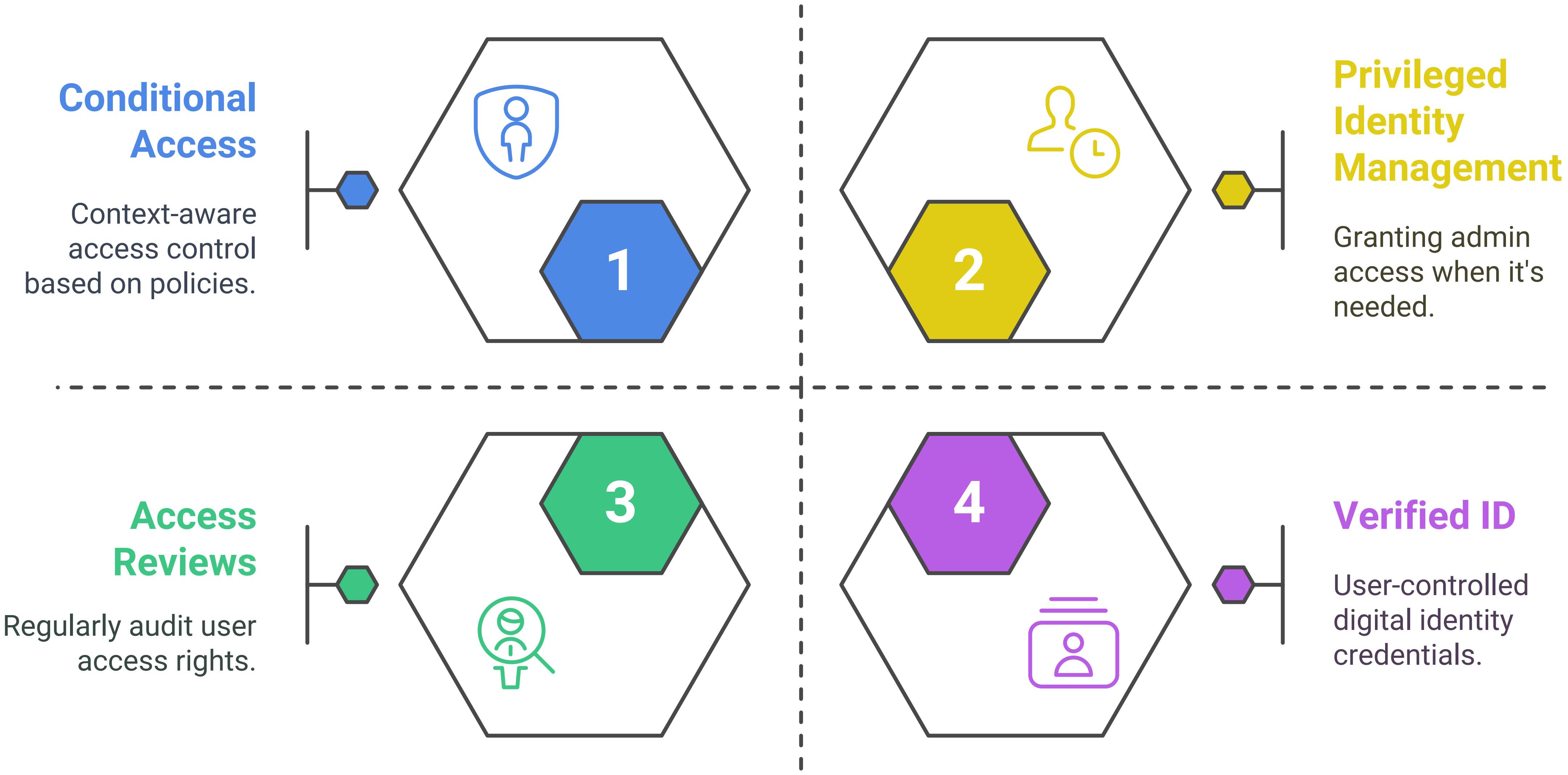
- **Authorization Methods:** How Access Decisions are Made
- **Least Privilege:** KEY PRINCIPLE - Minimum Necessary Access
- **RBAC (Role-Based Access):** Assign Permissions via Roles (Simpler Mgmt)



Access Control & Lifecycle

- **Conditional Access:** KEY POLICY ENGINE - If/Then Access Rules (Context Matters!)
- **PIM (Privileged Identity Mgmt):** Just-in-Time (JIT) Admin Access
- **Access Reviews:** Periodic Checks to Prevent Permission Creep
- **Verified ID (Concept):** Decentralized, User-Controlled Credentials (Links to Entra Product)

Identity Management Features



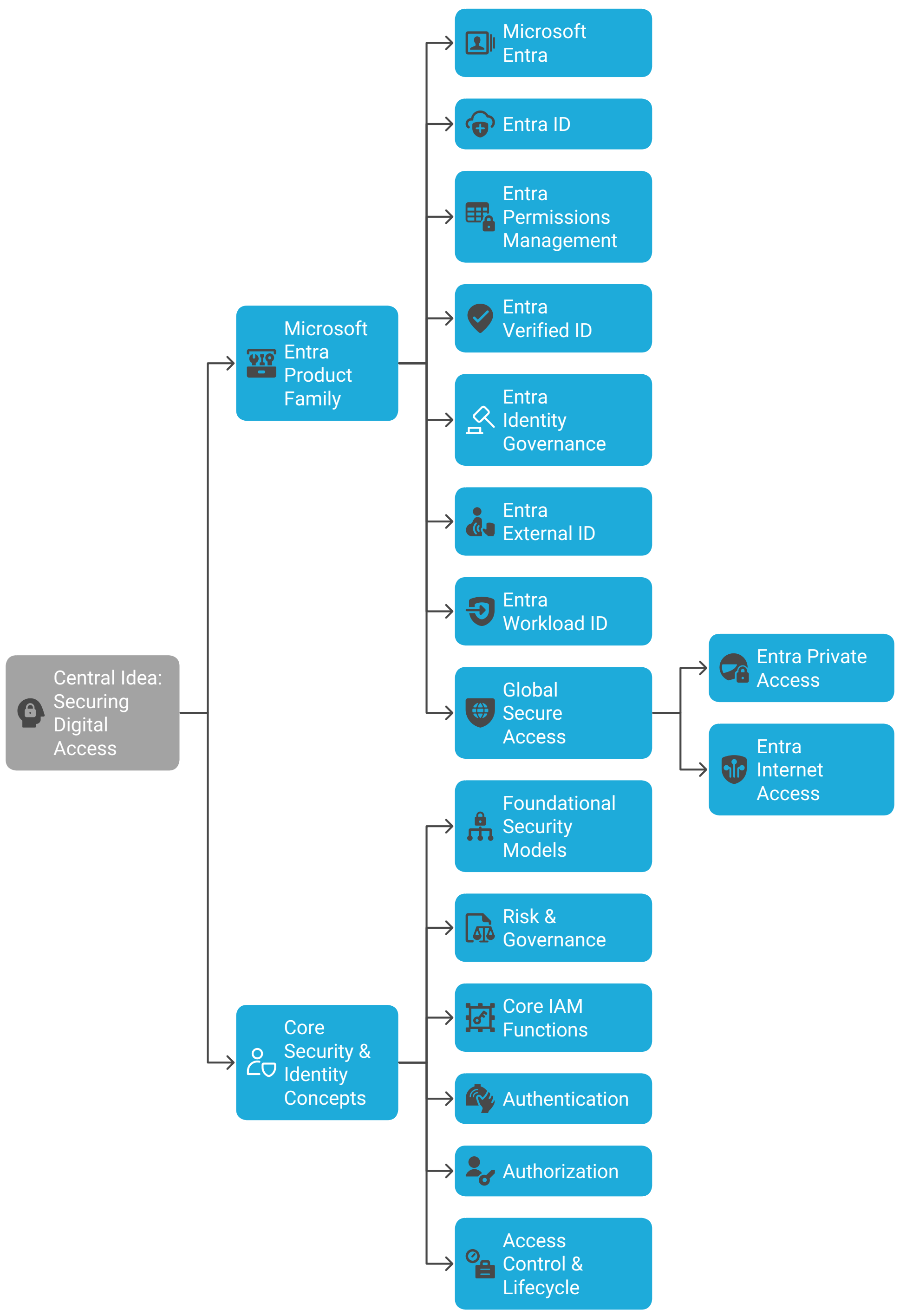
This document serves as a foundational guide for understanding the tools and principles necessary for securing digital access in today's complex environments.

This structure should help you visualize the connections between Microsoft Entra and the broader security concepts for easier recall.
Imagine this as branches spreading out from a central idea:

```
    ** 🧠  CENTRAL IDEA: SECURING DIGITAL ACCESS (Microsoft Entra
& Identity Concepts) 🧠  * *

         |
    +--- **I. MICROSOFT ENTRA PRODUCT FAMILY (The Tools)** 🛠️‼️
         |   |
    |   +--- **Microsoft Entra (Overall Brand)** - Unified
Identity & Access Management
    |   |
    |   +--- **Entra ID (Core Foundation - Formerly Azure AD)**
    |   |   |   `-->` What: Cloud Identity Service (Users, Groups,
Sign-ins)
    |   |   |   `-->` Why: Authentication, Authorization, SSO, MFA
Foundation
    |   |   |   `-->` Example: Employee Login to M365/Salesforce
    |   |
    |   +--- **Entra Permissions Management (CIEM)**
    |   |   |   `-->` What: Multi-Cloud Permissions Visibility
(Azure, AWS, GCP)
    |   |   |   `-->` Why: Discover & Right-size Permissions,
Least Privilege Across Clouds
    |   |   |   `-->` Example: Finding over-privileged AWS access
from Azure
    |   |
    |   +--- **Entra Verified ID**
    |   |   |   `-->` What: Decentralized Identity Credentials
    |   |   |   `-->` Why: User-Controlled, Verifiable Proofs
(Skills, Employment)
    |   |   |   `-->` Example: Digital Employee Badge for Instant
Verification
    |   |
    |   +--- **Entra Identity Governance**
    |   |   |   `-->` What: Identity Lifecycle & Access Assurance
Tools
    |   |   |   `-->` Why: Ensure Right Access, Right Time
(Reviews, Requests, PIM)
    |   |   |   `-->` Example: Automated Manager Access Reviews
    |   |
    |   +--- **Entra External ID (B2B/B2C)**
    |   |   |   `-->` What: Manage Customer, Partner, Guest
Identities
    |   |   |   `-->` Why: Secure External Access to Your Apps
    |   |   |   `-->` Example: Customer login to your web store
via Google
    |   |
    |   +--- **Entra Workload ID**
    |   |   |   `-->` What: Secure Non-Human Identities (Apps,
Services)
    |   |   |   `-->` Why: Secure App Authentication (No Hardcoded
Secrets)
    |   |   |   `-->` Example: Azure Function using Managed
Identity for Key Vault
    |   |
    |   +--- **Global Secure Access (SSE Umbrella)** 🌐
         |       |
    |       +--- **Entra Private Access (ZTNA)**
    |       |   |   `-->` What: Secure Access to Internal Apps
(VPN-less)
    |       |   |   `-->` Why: Modern Remote Access based on
Identity/Policy
    |       |   |   `-->` Example: Accessing On-Prem HR Portal via
Browser Securely
    |       |
    |       +--- **Entra Internet Access (SWG/Filtering)**
    |           |   `-->` What: Secure Access to Internet/SaaS
Apps
    |           |   `-->` Why: Protect Users, Enforce Web Policies
Anywhere
    |           |   `-->` Example: Blocking Phishing Sites for
Remote Users
    |
    |
    +--- **II. CORE SECURITY & IDENTITY CONCEPTS (The Principles &
Frameworks)** 🏛️‼️
                 |
        +--- **Foundational Security Models**
        |   |   `-->` **CIA Triad:** Confidentiality, Integrity,
Availability (Goals)
        |   |   `-->` **Defense in Depth:** Layered Security
(Castle Analogy)
        |   |   `-->` **Zero Trust Model:** Never Trust, Always
Verify (Modern Approach)
        |   |   `-->` **Cloud Shared Responsibility:** Provider
Secures OF Cloud, You Secure IN Cloud
        |
        +--- **Risk & Governance**
        |   |   `-->` **Security Threats:** The Dangers (Malware,
Phishing, etc.)
        |   |   `-->` **GRC:** Governance, Risk, Compliance
(Oversight & Rules)
        |   |   `-->` **IAM Governance:** Policies/Processes for
Managing Identities
        |
        +--- **Core IAM Functions**
        |   |   `-->` **IAM:** Identity & Access Management (The
Discipline)
        |   |   `-->` **AAA:** Authentication (Who?),
Authorization (What?), Accounting (Log)
        |   |   `-->` **Hybrid Identities:** On-Premises AD +
Cloud (Entra ID) Sync
        |
        +--- **Authentication (Proving Who You Are)**
        |   |   `-->` **Authentication Methods:** Passwords,
Biometrics, Keys, Apps...
```

Securing Digital Access with Microsoft Entra



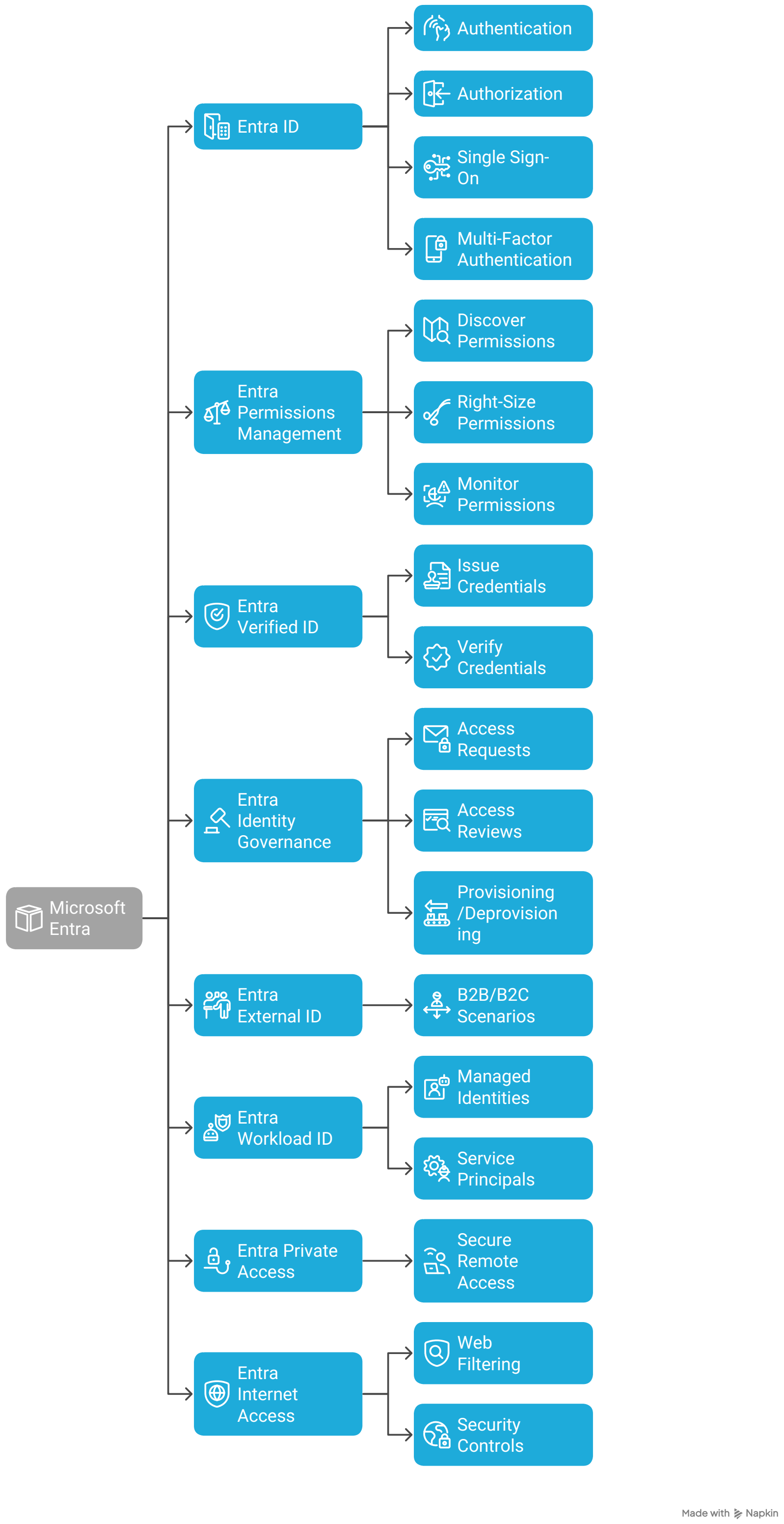
Made with Napkin

How to Use This Mind Map for Recall:

1. **Start Central:** Focus on the main goal: Securing Digital Access.
2. **Two Main Branches:** See the split between the *Tools* (Entra Products) and the *Principles* (Core Concepts).
3. **Explore Entra Branch:** Go through each product – what is its specific job? (Core login, multi-cloud permissions, external users, etc.). Notice how Global Secure Access is an umbrella for Private and Internet access.
4. **Explore Concepts Branch:** Look at the logical groupings:
    - *Models:* Foundational ways of thinking about security (CIA, Zero Trust...).
    - *Risk/Governance:* How you manage and oversee security.
    - *IAM Functions:* The basic building blocks of identity management.
    - *Authentication:* How identity is *proven*. MFA is crucial here.
    - *Authorization:* What someone can *do* once authenticated. Least Privilege and RBAC are key.
    - *Control/Lifecycle:* How access is dynamically managed and reviewed (Conditional Access, PIM, Reviews).
5. **Connect Them:** Realize that the Entra products (Branch I) are implementations or tools used to achieve the Principles (Branch II). For example:
    - Entra ID implements *Authentication Methods*, *MFA*, and basic *Authorization*.
    - Entra Identity Governance implements *Access Reviews*, *PIM*, and supports *IAM Governance*.
    - Conditional Access policies in Entra ID are a prime example of the *Zero Trust Model* in action.
    - Entra Permissions Management directly addresses *Least Privilege* across clouds.

By visualizing these connections and groupings, it should be easier to remember the individual components and how they fit into the bigger picture of Microsoft Entra and modern identity security.

Microsoft Entra End-to-End Concepts



Microsoft Entra - End-to-End Concepts Explained

Table1

Concept / Feature Name	What It Is (The "What")	Why It's For (The "Why")	How To Use It (The "How" - High Level)	Example Scenario
Microsoft Entra (Overall)	The entire family of Microsoft identity and access management products. It's the brand name encompassing everything below.	To provide a unified and comprehensive way to secure access for everyone and everything (users, apps, devices, workloads) across your digital estate (cloud, on-prem).	You use the various components together, managed primarily through the Microsoft Entra admin center, to build your identity and access security strategy.	Your company uses Entra ID for employee logins, Entra Permissions Management for AWS access control, and Entra Verified ID for onboarding, all managed centrally.
Microsoft Entra ID	The core cloud identity service (what used to be Azure AD). Manages users, groups, and how they sign in.	To provide fundamental identity management: Authentication (sign-in), Authorization (what they can access), Single Sign-On (SSO), Multi-Factor Authentication (MFA).	Create/sync user accounts, create groups, configure Conditional Access policies (e.g., require MFA from risky locations), set up SSO for applications like Salesforce or M365.	An employee uses their company email and password (Entra ID credentials) + an authenticator app prompt (MFA) to log into Microsoft Teams and Salesforce seamlessly (SSO).
Microsoft Entra Permissions Management	A Cloud Infrastructure Entitlement Management (CIEM) solution. It looks at permissions across multiple clouds (Azure, AWS, GCP).	To discover, right-size, and monitor permissions everywhere. It helps enforce "least privilege" access across different cloud platforms, reducing risk from excessive permissions.	Connect your Azure subscriptions, AWS accounts, and GCP projects. Use the dashboard to visualize permissions, get recommendations for reducing access, and set up alerts.	You discover a developer's service principal in Azure has accidentally been given broad "Contributor" rights in an AWS S3 bucket it doesn't need and easily revoke it.
Microsoft Entra Verified ID	A service based on decentralized identity standards. Allows issuing and verifying digital credentials securely.	To enable individuals to own and control their identity information and prove specific things about themselves (like qualifications or employment) quickly and securely.	Set up the Verified ID service, define credential types (e.g., "Employee Badge", "Course Completion"), issue credentials to users, and configure apps to request/verify them.	A new hire presents a digital "Verified Employee" credential issued by HR during onboarding, instantly proving their identity without needing multiple manual checks.
Microsoft Entra Identity Governance	A set of tools focused on identity lifecycle and access control assurance.	To ensure the right people have the right access at the right time. Automates access requests, reviews, and provisioning/deprovisioning based on policies and roles.	Configure Access Packages (bundles of resources users can request), set up Access Reviews (managers review team access periodically), use Privileged Identity Management (PIM) for just-in-time admin rights.	A manager receives an automated email asking them to review their team's access to a sensitive finance application, ensuring only current, necessary members retain access.
Microsoft Entra External ID	Capabilities for managing identities outside your organization (customers, partners, guests).	To provide secure and user-friendly ways for external users (like customers or business partners) to access your applications and resources. Supports B2B and B2C scenarios.	Configure sign-up/sign-in user flows for customer apps, customize branding, enable social logins (Google, Facebook), invite guest users for collaboration in Teams/SharePoint.	Your company's public-facing web store allows customers to sign up and log in using their personal Google accounts or via an email one-time passcode (OTP).
Microsoft Entra Workload ID	Identity and access management specifically for non-human identities like applications, services, scripts, etc.	To secure how applications and services authenticate and access resources, moving away from less secure methods like storing secrets in code. Apply policies to these identities.	Register applications in Entra ID, use Managed Identities (system/user-assigned) for Azure resources, configure service principals, apply Conditional Access policies targeting workloads.	An Azure Function app automatically authenticates to Azure Key Vault using its Managed Identity (no passwords/keys needed) to retrieve a secret securely.
Microsoft Entra Private Access	Part of Microsoft's Security Service Edge (SSE) solution. Provides secure access to private/internal applications.	To give users secure remote access to internal company apps (web apps, network shares) without needing a traditional VPN, based on identity and device health policies.	Deploy Entra Private Access Connectors in your network near the resources, configure applications in Entra, create Conditional Access policies that leverage network access.	A remote employee securely accesses an old on-premises HR portal directly through their browser, enforced by Conditional Access, without connecting a full VPN client.
Microsoft Entra Internet Access	Another part of Microsoft's SSE solution. Secures access to the public internet and SaaS apps.	To protect users and enforce policies as they access the internet and cloud apps (like M365, Salesforce, etc.). Includes web filtering and security controls.	Configure traffic forwarding profiles, deploy the Global Secure Access client, create Conditional Access policies incorporating security controls for internet traffic.	An employee browsing the web from a coffee shop is automatically blocked from accessing known phishing sites, and access to unsanctioned SaaS apps is restricted by policy.

insert the table

Achieving Secure Digital Access